

F24-D-033-Emit

Project Team

Nawfal Waqar 21I-1914
Hassaan Jamil 21I-2774
Hadia Shahid 21I-1563

Session 2021-2025

Supervised by

Mr. Abdullah Abid

Co-Supervised by

Dr. Shahela Saif



Department of Computer Science

**National University of Computer and Emerging Sciences
Islamabad, Pakistan**

June, 2025

Contents

1	Introduction	1
1.1	Problem Statement	1
1.2	Scope	1
1.3	Modules	3
1.3.1	Module 1: Identification of Threats and Agent Creation	3
1.3.2	Module 2: Dataset Handling and Static Rule Detection	4
1.3.3	Module 3: Automation	6
1.3.4	Module 4: Web Application	6
1.4	User Classes and Characteristics	8
2	Project Requirements	11
2.1	Use-Cases/Event Response Tables	11
2.1.1	Use Cases	11
2.1.2	Use Cases for SIEM Solution Components	14
2.1.3	Event Response Table	20
2.2	Functional Requirements	22
2.2.1	Module 1: Agent Creation	22
2.2.2	Module 2: Logs Management	22
2.2.3	Module 3: Model Training	23
2.2.4	Module 4: User Dashboards	24
2.3	Non-Functional Requirements	25
2.3.1	Reliability	25
2.3.2	Usability	26
2.3.3	Performance	26
2.3.4	Security	27
2.4	Domain Model	27
3	System Overview	29
3.1	Architectural Design	29
3.2	Design Models	31
3.2.1	Activity Diagram	31
3.2.2	Data Flow Diagrams	32
3.2.3	System-Level-Sequence Diagram	34

3.2.4	State Transition Diagram	35
3.2.5	Entity Relation Diagram	36
3.3	Data Design	37
3.3.1	Transform and Structure Data	37
3.3.2	Information Flow and Transformation	38
3.3.3	Databases and Data Storage Components of the System	38
References		39

List of Figures

1.1	Architecture of Emit	2
1.2	Agent creation	4
1.3	Data labelling and static rule detection	5
1.4	Module 3 of Emit	8
2.1	Use case diagram of Emit	21
2.2	Domain model of Emit	28
3.1	Final architecture diagram of Emit	30
3.2	Activity diagram of Emit	31
3.3	Data flow diagram Level-0 of Emit	32
3.4	Data flow diagram Level-1 of Emit	33
3.5	System-level-sequence diagram of Emit	34
3.6	State Transition Diagram of Emit	35
3.7	Entity Relation Diagram of Emit	36

List of Tables

2.1	UC-01 of Emit	11
2.2	UC-02 of Emit	12
2.3	UC-03 of Emit	12
2.4	UC-04 of Emit	12
2.5	UC-05 of Emit	12
2.6	UC-06 of Emit	13
2.7	Extended usecase: EUC-01	14
2.8	Extended usecase: EUC-02	15
2.9	Extended usecase: EUC-03	16
2.10	Extended usecase: EUC-04	17
2.11	Extended usecase: EUC-05	18
2.12	Extended usecase: EUC-06	19
2.13	Event Response Table of Emit	20

Chapter 1

Introduction

1.1 Problem Statement

Many organizations like FAST often give priority to monitoring external traffic and the threats it poses. They invest in firewalls and SIEM solutions to manage these risks. However, internal network traffic is frequently overlooked, despite the evidence showing us that the employees pose a greater and more critical threat to an organization. Insider threats, mostly driven by disgruntled employees, have been on the rise and are considered more dangerous than external attacks. The insider threats have become more dangerous since COVID-19 appeared, as it forced organizations to allow remote work to employees, while having little to no services to monitor them. According to a survey by OpenVPN, 73% of vice-presidents and C-Suite IT executives believe remote workers pose a greater risk than on-site employees [1]. These are the main concerns that define our problem statement.

1.2 Scope

Our proposed solution will be focused on monitoring and protecting internal networks. Initially, we will identify insider threats and the behavior malicious insiders follow. After identification, we will create agents that will be configured according to our identified insider threat behaviors. These agents will help us consolidate logs from end systems in our internal network onto a central system. This central system will include a log preprocessing tool, most likely Wazuh, that will help us send preprocessed and formatted logs to our system where we will visualize these logs onto the web application, and also collect these logs to create a dataset that will help us train our AI model for real time behavioral analysis and detection. For the time being, we will use static rule detection for our insider threat detection engine, Emit. After our model has been trained and tested,

we will integrate it onto our detection engine, Emit. This will allow us to detect insider threats both statically and using AI model.

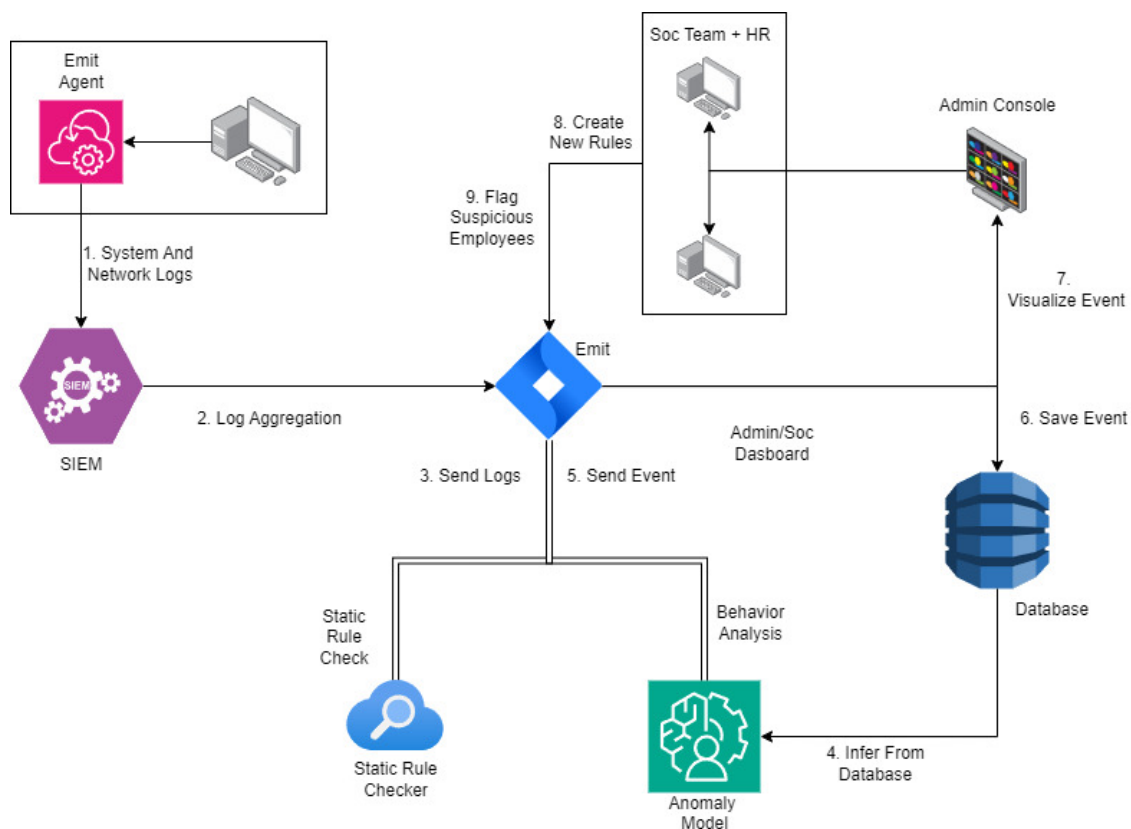


Figure 1.1: Architecture of Emit

1.3 Modules

1.3.1 Module 1: Identification of Threats and Agent Creation

The first part of our project is all about getting a clear picture of insider threats by identifying and labeling different behaviors that could signal a risk. We'll start by building a detailed list of these behaviors to help us understand what to look for. After this, we'll move on to setting up and configuring monitoring agents that will track and collect the necessary data. Once everything is set up, these agents will be deployed across our systems, allowing us to detect and report potential threats in real-time.

1. **Identifying Threats And Behaviors:** This part of the module includes creating an understanding of how insider threats work and the pattern that follows. We will be documenting the threats and behaviors that will allow us to configure our agents to search for the right logs in the end systems.
 - **Identification of threats:** This includes identifying insider threats and documenting them for future use.
 - **Understanding behaviors that lead to attacks:** This includes understanding the behaviors that eventually lead to insider attacks.
 - **Identifying what logs are needed:** After documentation and understanding of insider attacks, we will be able to identify what type of logs we need to extract from our systems.
2. **Agent Creation:** This part of the module focuses on creating agents according to the understanding we have developed from the previous work. The following actions will be performed:
 - **Agent Creation:** This step includes writing the script as a framework for log generation as well as a small application that can be downloaded.
 - **Agent Configuration:** After creation of agents, we will configure them according to our needs and what data they will extract for us from the systems in our network.
 - **Agent Deployment:** After Configurations, these agents will be deployed in multiple end systems and then tested.



Figure 1.2: Agent creation

1.3.2 Module 2: Dataset Handling and Static Rule Detection

The second module will focus on creating a dataset from the logs generated by the deployed agents. This dataset will be labeled to categorize different types of insider threat behaviors. Simultaneously, the logs will also undergo static rule detection, where predefined rules will be applied to detect threats in real-time.

1. **Dataset Creation:** The second module will focus on creating a dataset from the logs generated by the deployed agents. This dataset will be labeled to categorize different types of insider threat behaviors. Simultaneously, the logs will also undergo static rule detection, where predefined rules will be applied to detect threats in real-time.
 - **Storing Logs:** Logs received from agents will be stored in a database.
 - **Pre-processing of Logs:** This step involves cleaning the logs to remove irrelevant and dirty data, also giving logs a structure and format.
 - **Identifying Fields:** We will identify what fields we need in our dataset.
 - **Dataset Creation:** After these steps, the dataset finalization will be on the way.
2. **Dataset Labelling:** This part focuses on assigning labels to the dataset created from the logs. It will include the following steps:
 - **Labeling Threat Categories:** Labelling threats intensity according to a scale.
 - **Tagging Event Types:** Categorizing log events
 - **Validation of Labels:** Revision to check if the labelling was correct.
3. **Static Rule Detection:** This part involves applying static rule detection on the logs to identify predefined threats. It will include the following steps:
 - **Rule Set Creation:** This step will involve identifying the rules needed, and then creating a rule set.

- **Implementing Rules:** These rules will be enforced onto the logs using our engine.
- **Monitoring & Alerting:** Threat detection will be underway after the above two features are implemented.
- **Rule Refinement:** Reviews of rule set to keep us updated on newer threats.

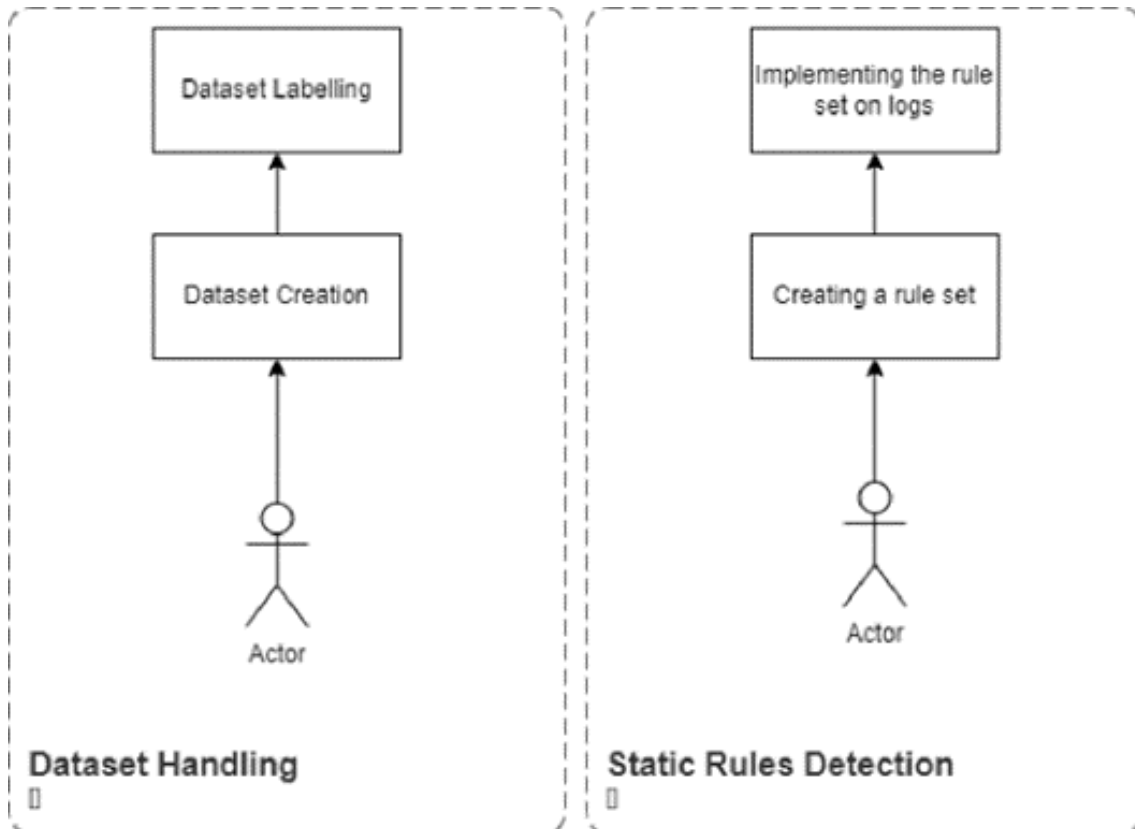


Figure 1.3: Data labelling and static rule detection

1.3.3 Module 3: Automation

The third module focuses on automating the detection process by incorporating machine learning models. This begins with training the model using the dataset created from the logs, where the labeled data will allow the model to learn patterns associated with insider threats. Once the model is trained and evaluated for accuracy, it will be fine-tuned to minimize false positives and enhance its detection capabilities. Afterward, the automated detection will be integrated into the SIEM system's detection engine, enabling real-time identification of insider threats.

1. **Model Training:** This part involves using the dataset created and labelled earlier to train our AI model. As for now, we will not be looking at deep learning models as there is no need for them. The classification model isn't defined as of yet, because we will analyze that as we move forward in our progress.
2. **Integrating Automation:** This part involves using the trained AI model to detect real time threats by integrating it onto our detection engine. After this, our engine will be capable of both, static and AI assisted detection and monitoring.

1.3.4 Module 4: Web Application

The fourth module involves the development of a web application that will serve as the interface for the SIEM system. The features and the application architecture are following:

- **Features:**
 1. **User Dashboards:** Customizable dashboards displaying real-time security alerts, system performance metrics, and key insights.
 2. **Alert Visualization:** Interactive visualizations of alerts and threat patterns, including charts, graphs, and heatmaps.
 3. **Log Management:** Access to detailed logs with search, filter, and export functionalities for in-depth analysis.
 4. **Incident Management:** Tools for tracking and managing security incidents, including case management and workflow automation.
 5. **Integration with Detection Systems:** Seamless integration with both automated detection and static rule-based systems for comprehensive threat monitoring.
 6. **User Access Control:** Role-based access control to ensure that users have appropriate permissions based on their roles and responsibilities.

7. **Real-Time Notifications:** Alerts and notifications sent to users for immediate response to detected threats or system anomalies.
- **Application Architecture:** The web application architecture will be designed to ensure a seamless and efficient interaction between the user interface, backend services, and data storage. The architecture includes the following components:
 1. **User Dashboards:** Customizable dashboards displaying real-time security alerts, system performance metrics, and key insights.
 2. **Frontend (UI):** Developed using React, the frontend will provide a dynamic and responsive user interface. React's component-based architecture will enable efficient rendering and interaction with the application, including dashboards, visualizations, and log management tools.
 3. **Backend:** Node.js will be used for the backend services, handling server-side logic, data processing, and communication between the frontend and the database. Node.js's non-blocking architecture will ensure scalability and performance.
 4. **Database:** MongoDB will serve as the database, storing logs, user data, and configuration settings. Its flexible schema design will accommodate various types of data and support efficient querying and indexing.
 5. **APIs:** RESTful APIs will be implemented to facilitate communication between the frontend and backend. These APIs will handle requests for data retrieval, updates, and interaction with the detection systems.
 6. **Integration:** The backend will integrate with the automated detection engine and static rule detection systems to provide real-time data and alerts. It will also manage user authentication and authorization, ensuring secure access to the application's features.

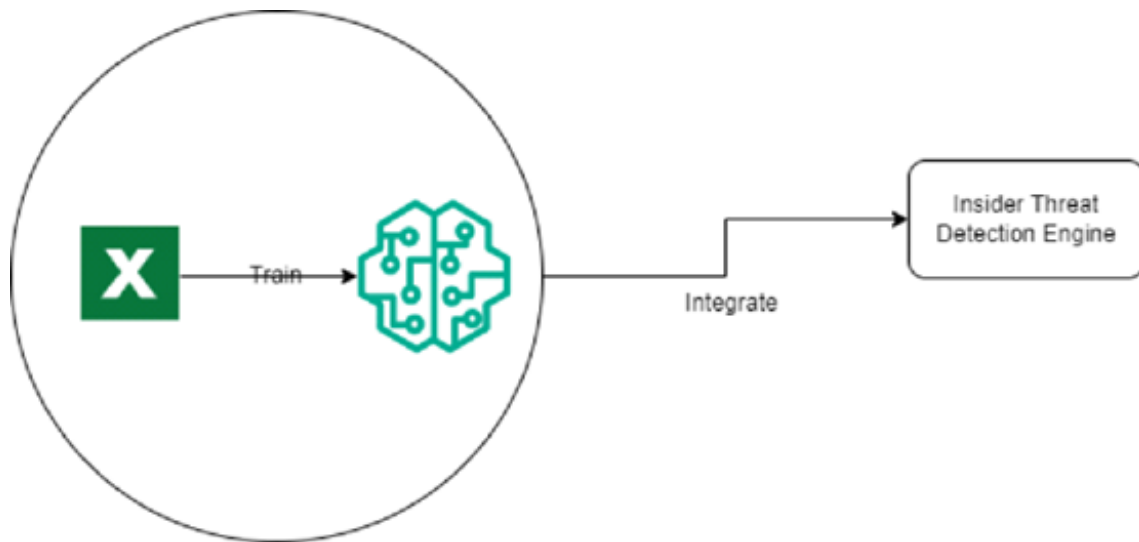


Figure 1.4: Module 3 of Emit

1.4 User Classes and Characteristics

User class	Description
Security Analysts	Definition: Cyber security professionals who monitor a system that responds to alerts of a potential insider threat. Applicable Traits: • Technical: Fully competent on security tools, data analysis, and comprehension of threat intelligence. • Needs: Real-time alerting into suspicious behavior, detailed logs of access, and insights gained through AI-based analytics. • Focus: Very much concerned about threat identification and handling to ensure that a threat does not compromise the overall security posture of an organization. • Interface: Employing security dashboards, customizable reports, and data visualizations for the tracking of employee behavior patterns.
IT Administrators	Job Description: Installing, configuring, and maintaining an insider threat detection system in a technical manner. Character Traits: • Technical Skills: Good technical knowledge of system management, network security, and integration of security tools. • Tools Enlisted: Management of system performance tools, high availability tools, and configuring the system according to organizational policies. • Security Requirements: The system should be secure with no disruption to other services. • Interface: Primarily through administrative panels, system logs, and configuration tools.
Personnel from HR Department	Description: HR personnel may use portions of the system to conduct employee conduct research from an internal HR operations perspective. Relevant Properties: • Technical Skills: From basic to intermediate, with a greater focus on understanding employee behavior. • Needs: Access to reports or dashboards for tracking anomalous employee behaviors in a non-technical format. • Interface: Use of simplified reports, graphical summaries, and behavioral indicators. • Security Concerns: Confidentiality and privacy in handling employee data.

Compliance and Legal Officers	Job Description: Ensure that the system complies with relevant legal and regulatory requirements, such as data privacy acts. Relevant Characteristics: • Technical Competencies: Average, with a focus on legal compliance rather than technical proficiency. • Requirements: Access to audit trails, detailed logs of system operations, and behavior tracking to ensure compliance with regulatory requirements. They need transparency in the AI decision-making process. • Security-Related: High, with a focus on the legality and morality of employee monitoring tools. • User Interface: Audit logs, compliance reports, and AI explanations of decisions.
Executive and Business Managers	Definition: Top-level decision-makers who may not necessarily use the system but rely on high-level information to gauge their exposure to organizational risk. Relevant Characteristics: • Technical Ability: Minimal, understanding derived from reports that provide insights into the overall security health. • Needs: High-level summaries, risk assessments, and recommendations. • Security Concern: Strategic focus on protecting the organization from insider threats, balancing legal and ethical considerations. • Interface: High-level executive reports and risk dashboards.

Chapter 2

Project Requirements

This chapter describes the functional and non-functional requirements of the project.

2.1 Use-Cases/Event Response Tables

2.1.1 Use Cases

Table 2.1: UC-01 of Emit

ID	UC-01
Use Case	Incident Response and Investigation
Actor	Incident Response Team
Type	Primary
Description	After an attack, the incident response team is responsible for identifying the nature of the security breach, containing the threat to prevent further damage, and gathering evidence for analysis. They will follow standard procedures to investigate the incident, mitigate its impact, and work towards recovering affected systems and data. Additionally, the team will document findings and coordinate with other departments to ensure future prevention measures are implemented.

Table 2.2: UC-02 of Emit

ID	UC-02
Use Case	Analyze Security Alerts and Generate Reports
Actor	Incident Response Team
Type	Primary
Description	The incident response team analyzes collected logs and alerts to identify security threats. Reports are generated to highlight patterns, trends, or identified threats. These reports are presented to management for review and decision-making. If no suspicious activity is found, the report indicates "No Threat Identified."

Table 2.3: UC-03 of Emit

ID	UC-03
Use Case	Manage Detection Rules
Actor	Incident Response Team
Type	Primary
Description	The team updates Emit's detection rules to accommodate newly discovered security threats. New rules are tested in a controlled environment and implemented after validation. The performance of these rules is monitored and adjusted as necessary to maintain security and system stability.

Table 2.4: UC-04 of Emit

ID	UC-04
Use Case	Centralize and Manage Logs
Actor	Incident Response Team
Type	Primary
Description	Logs generated from multiple systems are collected and centralized. The team monitors the logs, ensuring proper retention and storage practices. If log storage reaches capacity, an alert is triggered, and corrective action is taken.

Table 2.5: UC-05 of Emit

ID	UC-05
Use Case	Ensure Compliance with Security Policies
Actor	HR and Legal
Type	Primary
Description	The HR and Legal teams review security alerts and logs generated by Emit to ensure compliance with organizational security policies. Compliance reports are prepared, and violations are flagged for corrective action. If new regulatory requirements arise, policies and rules are updated accordingly.

Table 2.6: UC-06 of Emit

ID	UC-06
Use Case	Flag Suspicious Employees
Actor	HR and Legal
Type	Primary
Description	HR and Legal teams monitor employee behavior for unusual activities or violations of conduct using Emit. Suspicious behaviors are flagged for further investigation, with contextual factors considered. Reports on flagged employees are prepared, and corrective actions are taken if necessary.

2.1.2 Use Cases for SIEM Solution Components

Table 2.7: Extended usecase: EUC-01

Use Case ID	EUC-01
Use Case Name	Incident Response and Investigation
Scope	Emit (Incident Response Module)
Primary Actor	Incident Response Team (including Security and Forensic Analysts)
Preconditions	• Emit is operational. • A security incident is detected, and an alert message is issued.
Post Conditions	• The incident is thoroughly investigated, and remediation is applied. • Actions taken are documented.
Trigger	Emit issues a security alert.
Main Success Scenario	1. Emit sends an alert for a detected security incident. 2. The Incident Response Team is notified. 3. The team reviews alert details and incident logs. 4. Investigation is conducted to determine the cause and impact of the incident. 5. Remediation steps, such as blocking access or removing malicious content, are implemented. 6. Actions taken are recorded in the incident management system.
Alternate Flow	If determined to be a false positive, the alert is marked as resolved without further action.
Exception Flow	If the incident escalates into a greater threat, the team notifies top management for additional resources.

Table 2.8: Extended usecase: EUC-02

Use Case ID	EUC-02
Use Case Name	Analyze Security Alerts and Generate Reports
Scope	Emit (Security Analysis Module)
Primary Actor	Incident Response Team
Preconditions	• Logs are collected and stored from various systems. • Alerts are generated by Emit's detection models.
Post Conditions	• Reports are generated and presented to management. • Patterns or trends are identified for future threat detection.
Trigger	Logs and alerts are ready for analysis.
Main Success Scenario	1. The system generates logs and alerts for review. 2. The team identifies patterns or potential security threats. 3. A detailed report of findings is created. 4. The report is presented to management for review and decision-making.
Alternate Flow	If no suspicious activity is detected, the report indicates "No Threat Identified."
Exception Flow	If logs are incomplete, an error notification is issued, and the issue is escalated to IT.

Table 2.9: Extended usecase: EUC-03

Use Case ID	EUC-03
Use Case Name	Manage Detection Rules
Scope	Emit (Detection Rules Module)
Primary Actor	Incident Response Team
Preconditions	• Emit is running with preconfigured detection rules. • A new security threat requires updates to the rules.
Post Conditions	• New rules are added, and existing rules are updated for improved accuracy.
Trigger	A new threat is discovered.
Main Success Scenario	1. A new threat or security pattern is identified. 2. The team generates or updates detection rules. 3. The updated rule is tested in a controlled environment. 4. After validation, the updated rule is implemented in the live system. 5. Rule performance is monitored for necessary adjustments.
Alternate Flow	If no changes to detection rules are required, the team continues monitoring for new threats.
Exception Flow	If rule updates cause instability, changes are rolled back to the previous rule.

Table 2.10: Extended usecase: EUC-04

Use Case ID	EUC-04
Use Case Name	Centralize and Manage Logs
Scope	Emit (Log Management Module)
Primary Actor	Incident Response Team
Preconditions	• Logs are generated from various sources. • A centralized log management system is in place.
Post Conditions	• All logs are centralized, captured, and available for viewing.
Trigger	Logs are generated from multiple sources.
Main Success Scenario	1. Logs are collected from network devices, systems, and applications. 2. Logs are centralized within the log management system. 3. The team monitors the flow of logs to ensure proper storage. 4. Logs are archived or deleted according to retention policies.
Alternate Flow	If no logs are generated from certain systems, the team checks system health and log generation status.
Exception Flow	An alert is triggered if log storage reaches capacity.

Table 2.11: Extended usecase: EUC-05

Use Case ID	EUC-05
Use Case Name	Ensure Compliance with Security Policies
Scope	Emit (Compliance Module)
Primary Actor	HR and Legal
Preconditions	• Compliance rules and regulations are defined. • Emit is deployed and logging security events.
Post Conditions	• A compliance audit is conducted with no violations reported.
Trigger	Continuous monitoring of security events.
Main Success Scenario	1. The team reviews Emit for security alerts and logs against pre-defined policies. 2. Compliance violations are identified and flagged. 3. Reports on compliance status are prepared. 4. If violations are found, corrective actions are performed.
Alternate Flow	If no violations are detected, compliance reports are prepared periodically.
Exception Flow	Regulatory requirements change, prompting updates to rules and policies.

Table 2.12: Extended usecase: EUC-06

Use Case ID	EUC-06
Use Case Name	Flag Suspicious Employees
Scope	Emit (HR Surveillance Module)
Primary Actor	HR and Legal
Preconditions	• Compliance rules and regulations regarding employee conduct are defined. • Emit is deployed and logging relevant security events and employee behavior.
Post Conditions	• Suspicious employee behaviors are flagged for further investigation. • Appropriate actions are documented and communicated to relevant stakeholders.
Trigger	Continuous monitoring of employee behavior and security events.
Main Success Scenario	1. HR and Legal regularly review alerts and logs from Emit for potential indicators of suspicious behavior. 2. The team identifies behaviors that may suggest a risk, such as unusual access patterns, communications, or activities outside normal parameters. 3. Contextual factors are considered, such as recent disciplinary actions, terminations, or plans for leaving the organization. 4. Employees exhibiting concerning behaviors are flagged for further evaluation and monitoring. 5. A report on flagged employees and observed behaviors is prepared for management. 6. If necessary, corrective actions, such as increased supervision or intervention, are implemented based on the findings.
Alternate Flow	If no concerning behaviors are identified, the monitoring process continues without flagging any employees.
Exception Flow	If an urgent threat is identified related to a flagged employee, immediate escalation occurs to management and security for rapid response.

2.1.3 Event Response Table

Table 2.13: Event Response Table of Emit

Event Type	Description	Severity	Response Action
Unauthorized Access	An attempt to access a restricted area.	High	Alert Security Team
Malware Detected	Malicious software identified in the system.	Critical	Isolate Infected System
Suspicious Activity	Unusual behavior detected in user accounts.	Medium	Monitor User Activity
Data Exfiltration	Unauthorized transfer of data outside the network.	Critical	Block Data Transfer
Phishing Attempt	An attempt to deceive users into revealing credentials.	High	Send Alert and Educate Users
Denial of Service Attack	Attempt to overwhelm system resources.	High	Activate DDoS Mitigation
Configuration Change	Unauthorized changes made to system configurations.	Medium	Review and Rollback Changes
Failed Login Attempts	Multiple unsuccessful login attempts detected.	High	Lock User Account and Investigate
New User Account Creation	Unauthorized creation of a new user account.	High	Review and Disable Account
Suspicious File Access	Access to sensitive files outside of normal hours.	Medium	Investigate Access Logs
Network Scanning	Scanning for open ports or vulnerabilities detected.	Medium	Alert Security Team
Account Privilege Escalation	User account gaining unauthorized elevated privileges.	Critical	Investigate and Revoke Privileges
System Anomalies	Unusual CPU or memory usage patterns detected.	Medium	Analyze Logs and Correlate Data
Application Crashes	Critical applications crash unexpectedly.	High	Investigate Application Logs
Compliance Violation	Detection of actions violating compliance policies.	High	Notify Compliance Officer
Unusual Outbound Traffic	Sudden increase in outbound traffic detected.	High	Investigate Source and Block Traffic

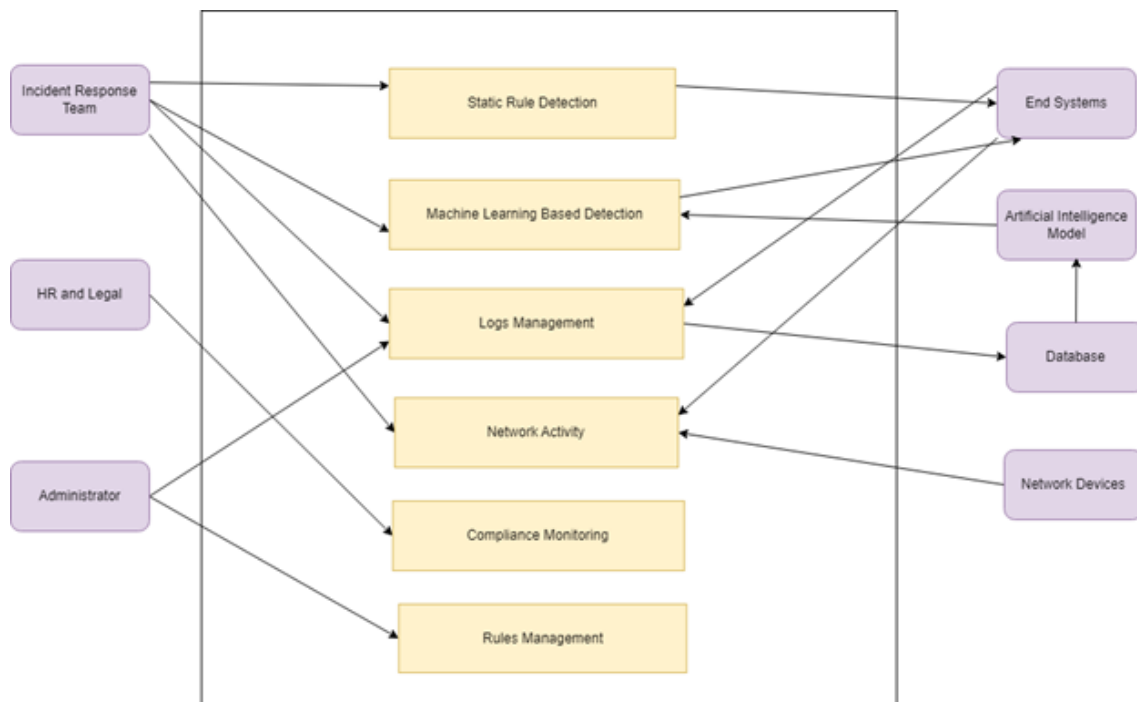


Figure 2.1: Use case diagram of Emit

2.2 Functional Requirements

2.2.1 Module 1: Agent Creation

Following are the requirements for Module 1:

- FR1: The system shall provide a designed environment for the creation of the monitoring agents that collect and generate logs from the computer endpoints.
- FR2: The system shall be designed to enable scripting agent development using languages such as Python and PowerShell to increase usability.
- FR3: The system shall provide information for the developers on creating agents which will include templates and examples.
- FR4: The system shall provide a configuration file or interface for setting parameters such as: types of logs collection, data collection frequency, filters of certain event or threshold.
- FR5: The system shall permit the definition of agents by allowing the configuration of agents to determine if the agent will be deployed in polling mode or real-time.
- FR6: The system shall have a methodology in place to address testing of each agent deployed in the production environment.
- FR7: The framework shall contain the ability to run and create various scenarios to test the agents and confirm they work under those situations.
- FR8: The system shall provide a facility to the researcher to deploy the agent on more than one end system, methods including: scripts that can be executed from command line for deployment purposes.
- FR9: There are automated deployment options that can be done with the use of configuration management tools like Ansible, Puppet, etc.

2.2.2 Module 2: Logs Management

Following are the requirements for Module 2:

- FR1: The system shall have tools for retaining, in the central repository, logs that are generated by deployed agents.
- FR2: The system will support the Classification Shelves and Dunnage Warehousing Systems for logs of varying capacity.

FR3: Cleans logs by stamping out all non-essential or damaged data elements.

FR4: Standardizes the log entries to maintain global order.

FR5: The system should have a module for log records of preprocessing heads to support audits.

FR6: The system shall have tools to detect threats using a rule set.

2.2.3 Module 3: Model Training

Following are the requirements for Module 3:

FR1: The system will employ the labeled dataset developed in Module 2 in the training of the machine learning model.

FR2: The system will implement suitable methods to efficiently prepare and load the dataset in a training application.

FR3: The system will incorporate the performance evaluation of the classifier algorithms, and a decision will be made on the selected algorithms, for example, decision trees, random forests, and support vector machines.

FR4: The system will provide a facility for setting up the model parameters as well as the model hyperparameters pertinent to the algorithm deployed.

FR5: The system will introduce a training infrastructure capable of enabling functionalities related to the carrying out of the model training process with the selected algorithm and dataset in place.

FR6: The system will provide for dataset partitioning into training, validation, and test sets for purposes of testing the prediction accuracy of the model developed.

FR7: The system will perform and include a set of evaluation metrics for the model in terms of performance, for instance, accuracy, precision, recall, F1-score, and AUC-ROC, among others.

FR8: The system will also offer means of illustrating the results of the evaluation carried out on the model such that it will be easier for the analysts to comprehend the usefulness of the model.

FR9: The system shall allow adjustments to certain dimensions of the model, revisiting and making corrections based on evaluation results.

FR10: The system shall allow integration of the AI model based detection engine into the main application.

2.2.4 Module 4: User Dashboards

Following are the requirements for Module 4:

- FR1: The system shall provide users with customizable dashboards to display real-time security alerts and system performance metrics.
- FR2: The system shall allow users to rearrange and configure dashboard widgets according to their preferences.
- FR3: The dashboard shall include widgets for displaying key insights, such as the number of detected threats, system health status, and historical trends.
- FR4: The system shall provide options for users to choose which metrics to display on their dashboards.
- FR5: The system shall provide interactive visualizations of security alerts, including charts, graphs, and heatmaps to represent threat patterns.
- FR6: The visualizations shall allow users to drill down into specific alerts for more detailed analysis.
- FR7: Users shall be able to filter visualizations based on criteria such as alert severity, type, and time range.
- FR8: The system shall allow users to select specific time periods for visualizations, such as the last hour, day, or week.
- FR9: The system shall provide users with access to detailed logs generated by the detection systems.
- FR10: Users shall be able to view logs in a structured format that includes essential fields for analysis.
- FR11: The system shall include search functionality to allow users to quickly locate specific log entries based on various parameters (e.g., timestamp, source IP).
- FR12: Users shall be able to filter logs by severity, event type, and other relevant criteria.
- FR13: The system shall provide functionality for users to export logs in multiple formats (e.g., CSV, PDF) for offline analysis and reporting.
- FR14: The system shall include tools for tracking and managing security incidents, allowing users to log incidents and track their status.
- FR15: The system shall provide a workflow for escalating incidents based on severity and user preferences.

- FR16: Users shall be able to document incident details, including actions taken and evidence collected.
- FR17: The system shall provide features for assigning incidents to specific personnel or teams for resolution.
- FR18: The system shall automate certain workflows related to incident response, such as notifying relevant personnel when an incident is logged.
- FR19: The system shall integrate with both static rule detection and AI-assisted detection systems for comprehensive threat monitoring.
- FR20: The integration shall provide real-time data feeds into the application for up-to-date threat monitoring.
- FR21: The system shall aggregate alerts from both detection systems, allowing users to manage alerts through a unified interface.
- FR22: The system shall implement role-based access control to ensure users have appropriate permissions based on their roles (e.g., SOC L1, L2).
- FR23: The system shall allow administrators to define roles and assign specific permissions for each role.
- FR24: The system shall require user authentication for access, supporting secure login mechanisms (e.g., username/password, two-factor authentication).
- FR25: The system shall send alerts and notifications to designated personnel immediately when a threat or system anomaly is detected.
- FR26: Users shall be able to configure their notification preferences, such as alert types and communication channels (e.g., email, SMS).
- FR27: The system shall maintain a history of notifications sent to users, allowing them to review past alerts and responses.

2.3 Non-Functional Requirements

2.3.1 Reliability

Considering the consequences of missed detections or false positives, our solution will have to achieve a very high level of reliability as far as the detection of insider threats is concerned. Reliability is defined by the Mean Time Between Failures (MTBF), particularly in the areas of collecting and processing the logs.

- **Reliability Goal:** The system is designed with the assumption that its MTBF will not be less than 6 months in such a manner that active surveillance of the logs will be done with minimum interruptions.
- **Failure Definition:** The term failure for emit means the perceived failure of the system to gather, handle, or interpret the logs, or positive/negative risk assessments that could seriously impair the performance of the system.
- **Error Correction Strategy:** If the log processing is unsuccessful, the host-based agents will be reconfigured to affect a self-recovery by the system. In the event of a clinically dead error persistent log collection will be manually triggered.

2.3.2 Usability

For security analysts and system administrators, the system should be simple to understand, use, and engage with.

- **USE-1:** With no more than three interactions within the dashboard, the system should enable security analysts to examine and evaluate the alerts generated.
- **USE-2:** With a maximum response time of two seconds for each interaction, the web application should include real-time visualizations that let users swiftly evaluate the state of insider threat detection and recognize patterns in insider attacks that occur within their organization.
- **USE-3:** Security analysts should be able to view the list of users being monitored within one interaction.

2.3.3 Performance

Emit needs to continue operating at a high level, particularly when managing logs and immediately identifying insider threats with a minimum rate of false positives.

- **PER-1:** Incoming logs should be processed and analyzed by the system in real time, with a 5 second processing limit for log entries from any host system.
- **PER-2:** Threat warnings must be displayed by the web application two seconds after they are detected.
- **PER-3:** Without compromising speed, Emit should enable the smooth log consolidation of all host-based agents.
- **PER-4:** Emit should minimize the rate of false positives, through behavioral analysis.

2.3.4 Security

Safety has to be aligned with system protection as well as data processed by our solution, which emphasizes the detection and mitigation of insider threats.

- **SEC-1:** The system shall resist, at a minimum, the best efforts of an attacker for a period of at least 8 hours in making an unauthorized access from the external environment.
- **SEC-2:** All host-based agents must collect log and have encryption-in-transit and at rest for confidentiality and integrity.
- **SEC-3:** The system shall implement RBAC: the only access control mechanism; prohibit operations other than viewing, modification, or deletion of sensitive log data from being accessed by authorized persons.
- **SEC-4:** Any attempt to gain unauthorized access or modify the system should raise an alarm to the security team within less than 5 seconds after detection.

2.4 Domain Model

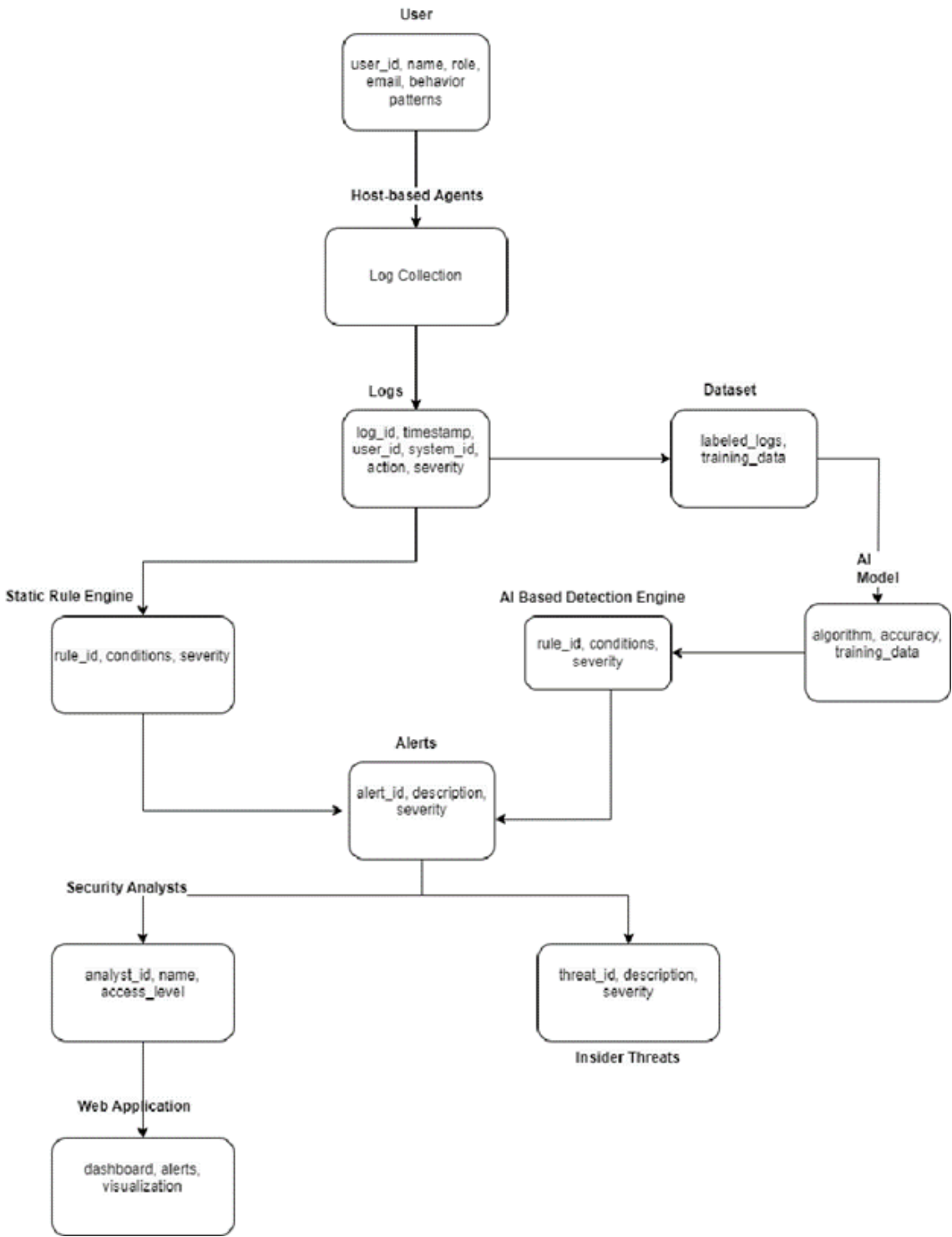


Figure 2.2: Domain model of Emit

Chapter 3

System Overview

3.1 Architectural Design

The **Emit Agent** first collects system and network logs from employees and sends them to the selected **SIEM** for aggregation. Once aggregated, these logs are forwarded to **Emit**, where the logs are then forked and sent in parallel to the **Static Rule Checker** and **Behavioral Analysis** modules. The **Static Rule Checker** analyzes logs against predefined rules, while the **Behavioral Analysis** module uses an AI-based **Anomaly Model** to detect suspicious patterns or behaviors checking multiple logs from users. If either module detects a threat, an event is generated and sent to the **Dashboard** for review. Detected events are also stored in the **database** for future analysis, and the **SOC Team** can create new rules based on flagged behaviors, enhancing Emit's ability to identify insider threats over time. Moreover, **HR** can Utilize the **HR Flagging System** to identify any employees that may be deemed High Risk. This Risk is sent to the Checkers who will then increase the severity of each action / event.

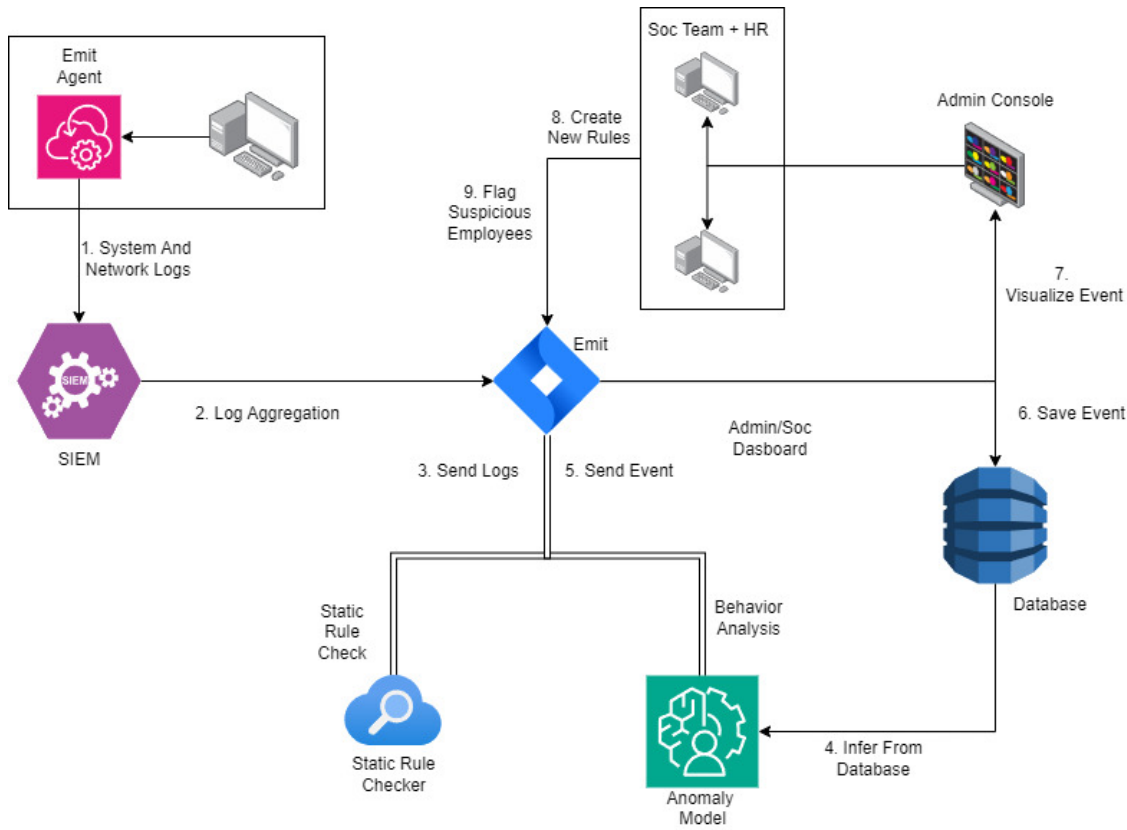


Figure 3.1: Final architecture diagram of Emit

3.2 Design Models

3.2.1 Activity Diagram

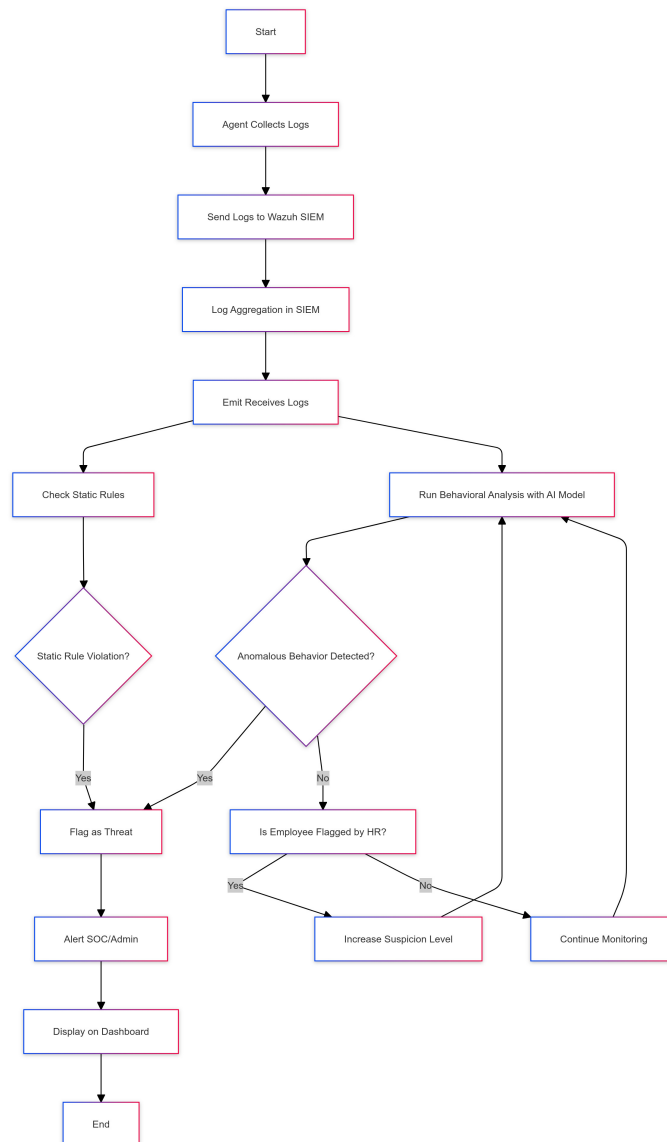


Figure 3.2: Activity diagram of Emit

3.2.2 Data Flow Diagrams

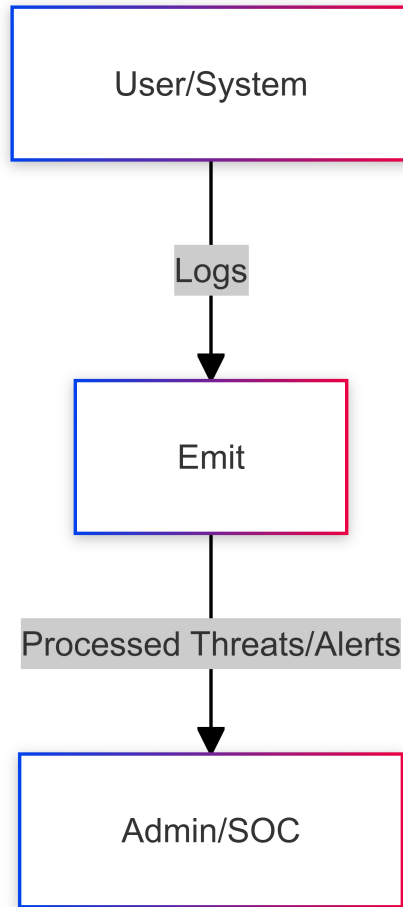


Figure 3.3: Data flow diagram Level-0 of Emit

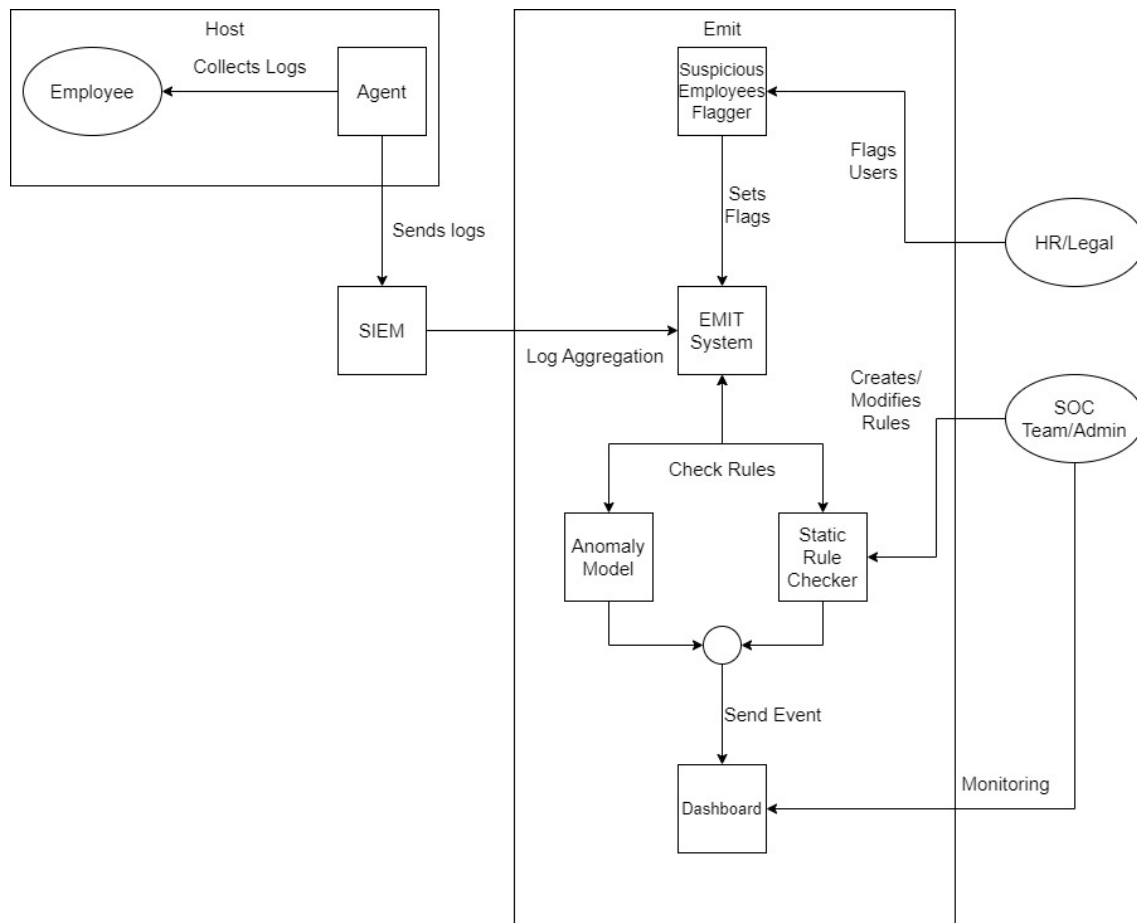


Figure 3.4: Data flow diagram Level-1 of Emit

3.2.3 System-Level-Sequence Diagram

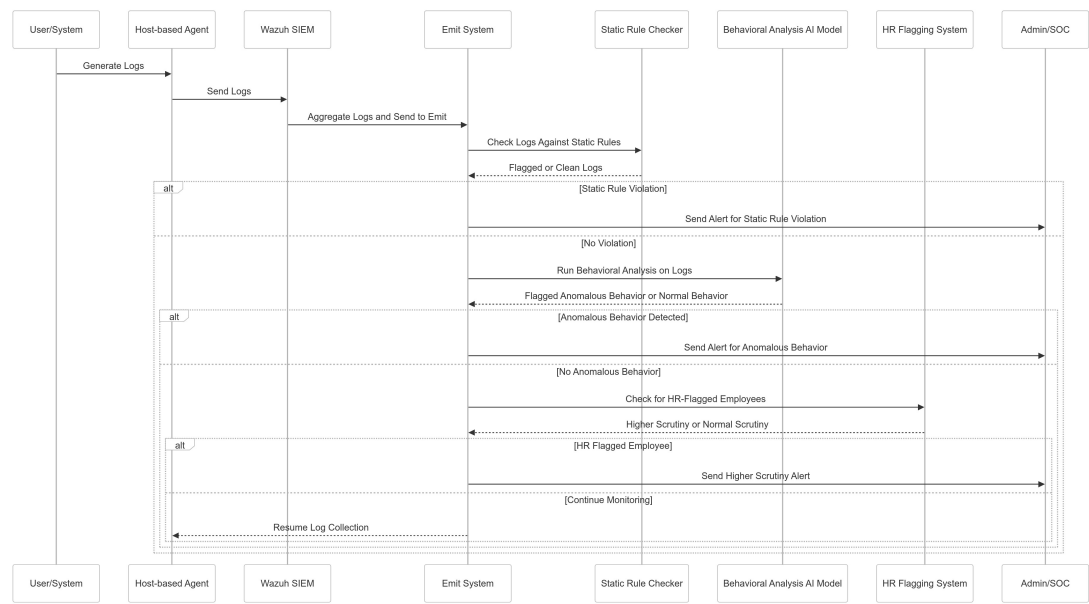


Figure 3.5: System-level-sequence diagram of Emit

3.2.4 State Transition Diagram

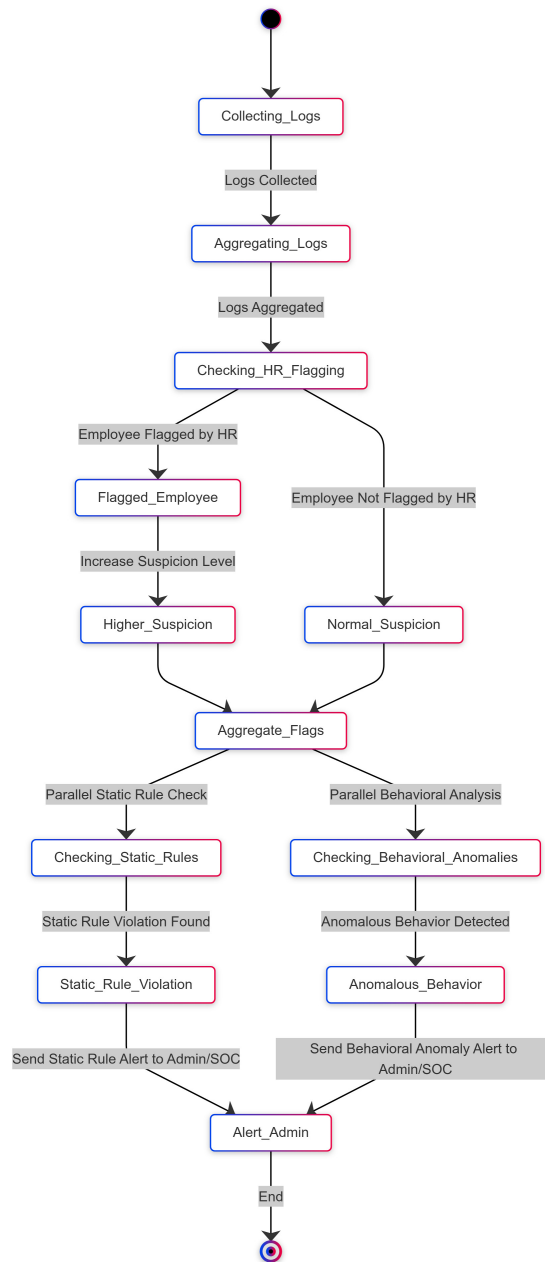


Figure 3.6: State Transition Diagram of Emit

3.2.5 Entity Relation Diagram

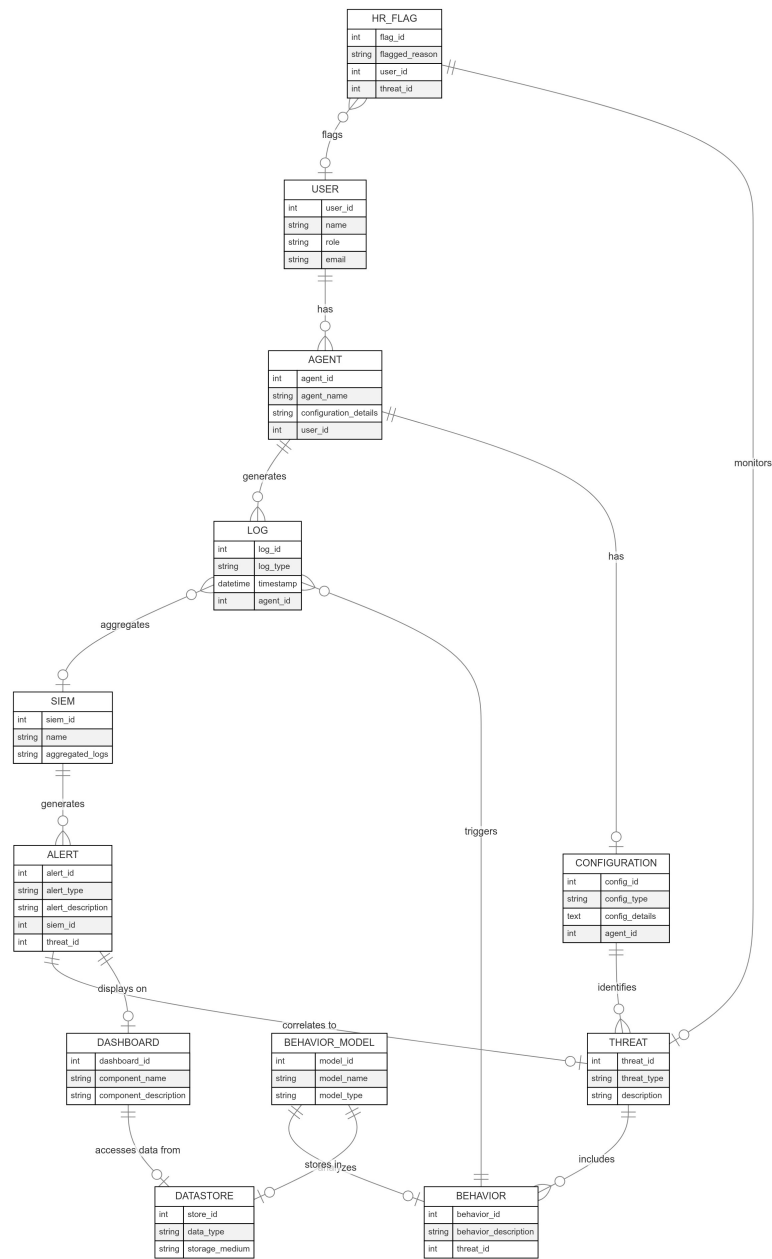


Figure 3.7: Entity Relation Diagram of Emit

3.3 Data Design

3.3.1 Transform and Structure Data

Information Flow:

The Emit component deals with processes, controls, and supervision or monitoring of any threats posed by users and their behaviors. Data logs are collected by agents and their output is integrated by a SIE (Security Information and Event Management) system while the Behavioral Model performs data processing in an order to identify any potential threats. This threat information is uploaded and retrieved in the SOC (Security Operation Center) dashboard.

Data Structure:

Window, User, Agent, Log, Thread and Behavior are examples of entities which are maintained in separate containers enabling fast processing of data and tracking of their inter-relationships.

Data Transformation:

Agent Logs are sent to a SIEM where they are merged and scrutinized. Threats and events are identified and put in reserve for analysis and actions by the SOC. Data Resourcing, Processing and Arrangement Log Collection: Agents are supposed to capture activity logs which are sent to a Log Data Store and further consolidated by a SIEM (Wazuh).

Threat Detection:

AI enhances the capacity of the Behavioral Model to scrutinize the conjoined logs and narrow down on probable threats identified by abnormal behavior. Static rule content eliminates known threats and issues within the SIEM and offers immediate notifications.

Alerting and Monitoring:

Any threats which have been identified are put aside and placed in the alert database. Alerts and users put on alert by the HR department are integrated and shown to Admin / SOC for Security clearance.

3.3.2 Information Flow and Transformation

Integration and Processing:

The Emit component handles the processes, controls, and supervision of threats posed by user behaviors. Data logs, collected by agents, are processed and integrated by a SIEM system, while the Behavioral Model performs data analysis to identify potential threats. This information is subsequently uploaded to and retrievable from the SOC dashboard.

Data Structure and Transformation:

- **Data Structure:** Entities such as Window, User, Agent, Log, Thread, and Behavior are maintained in separate containers to facilitate fast data processing and tracking of interrelationships.
- **Data Transformation:** Agent logs are sent to a SIEM where they are merged and scrutinized. The system identifies threats and reserves them for further analysis by the SOC.

3.3.3 Databases and Data Storage Components of the System

- **MongoDB:** Has functionality for storing records and provisions for behavioural data storage which enables the system to import data in both structured and un-structured formats.
- **Kafka:** Facilitates around the clock log streaming and its associated processing. It is very vital for fast data ingestion purposes.
- **Alert Store:** Keeps record of alerts information for ease of accessibility for the purpose of SOC and network audit.
- **Flagged User Store:** Keeps record of users flagged by HR for close monitoring in an effort to assist in linking users' actions and possible threats.

Bibliography